

Footprinting & Passive Reconnaissance

What is Footprinting?

Footprinting is the very first phase of ethical hacking. Before you try to break into anything, you need to understand your target. It's like a burglar studying a building before attempting entry — they'd want to know how many doors exist, what security cameras are installed, when guards change shifts, and so on.

In cybersecurity, you're collecting information about a target system, network, organization, or individual. The goal is to build a profile or blueprint that answers three questions: What is the target? How does it operate? Where might it be vulnerable?

Two Types of Reconnaissance

Reconnaissance splits into two categories based on whether you interact with the target directly.

Passive Reconnaissance means you gather information without the target ever knowing. You never send a single packet to their systems. You're using publicly available sources only. Examples include WHOIS lookups (checking who registered a domain), DNS record lookups, searching through Google, researching through social media, and browsing the Internet Archive. The target has zero way of detecting that you're investigating them.

Active Reconnaissance means you directly touch the target's systems. You send packets, you probe their network, you interact with their infrastructure. This includes ping sweeps, traceroutes, port scanning (Nmap), network scanning, social engineering (calling employees, phishing), and DNS footprinting. The key difference is that active recon can be detected and logged by the target's security systems.

Think of it this way: passive recon is like looking at someone's house from across the street using binoculars, while active recon is like walking up to their house and trying every door handle.

Passive Reconnaissance Tools & Techniques

Google Dorking (Advanced Google Hacking)

This is a powerful technique where you use special Google search operators to find information that's publicly available but not easily visible through normal searches. The syntax is always `operator:keyword`.

Here are the key operators. The `site:` operator restricts results to a specific domain — for example, `site:ostad.app` shows only pages from that website. The `inurl:` operator searches for keywords in the URL itself — `inurl:login` finds pages with "login" in their web address, which could reveal admin panels. The `intitle:` operator searches within page titles — `intitle:"index of"` is famous for finding directory listings where files are exposed. The `intext:` operator searches within page content — `intext:"password"` might find accidentally exposed credentials. The `filetype:` operator finds specific file types — `filetype:pdf` combined with a topic finds PDF documents on that subject. And `link:` finds pages that link to a specific site.

You can combine these for powerful searches. Something like `site:*.gov filetype:txt intext:"username" intext:"password"` searches government websites for text files containing both "username" and "password" — potentially finding exposed credential files.

Google Hacking Database (GHDB)

The GHDB at exploit-db.com is a curated collection of these Google dork strings organized into 14 categories. These categories include footholds (initial access points), files containing usernames or passwords, sensitive directories, vulnerable servers, error messages leaking technical details, exposed databases, login pages, and more. Security professionals use this to check if their own organization has accidentally exposed sensitive information.

SHODAN

While Google indexes websites, Shodan indexes internet-connected devices — servers, routers, webcams, IoT devices, databases, industrial control systems, and cloud services. For each device, Shodan collects the IP address, open ports, running services and their versions, operating system, geographic location, SSL certificates, and the organization/ISP.

Shodan has its own search filters. `port:22` finds devices with SSH open, `country:BD` filters by Bangladesh, `org:"Google"` filters by organization, `product:Apache` finds Apache web servers, `os:Windows` finds Windows machines, and `net:192.168.1.0/24` searches within an IP range.

The example from your slides — `port:3389 country:BD` — searches for devices in Bangladesh with Remote Desktop Protocol exposed. This found 4,447 results, meaning that many devices have RDP open to the internet, which is a significant security risk.

Internet Archive (Wayback Machine)

The Internet Archive at archive.org stores historical snapshots of websites. In reconnaissance, this is valuable because you can see older versions of a target's website that might have contained information they've since removed — old employee directories, deprecated technologies, previous server configurations, and contact information.

WHOIS

WHOIS is a protocol that queries databases containing domain and IP registration information. When someone registers a domain name, they provide contact information to their registrar. A WHOIS lookup can reveal the domain name owner, registrar name, registration and expiration dates, name servers (DNS), contact email and phone (though often hidden by privacy protection), and for IP addresses it shows the ISP, network range, country, and ASN number.

The WHOIS system works in layers. Your WHOIS client sends a query to a WHOIS server (listening on TCP port 43), which is maintained by domain registrars, ICANN, or Regional Internet Registries. That server may redirect your query to a more authoritative database that holds the actual registration records.

Tools for domain lookup include Netcraft, ICANN Lookup, DomainTools, Whois.com, DNSDumpster, and command-line tools like `whois`, `sublist3r`, `subfinder`, `nslookup`, and the Wappalyzer browser extension for identifying technologies used by a website.

DNS Reconnaissance Tools

Your slides cover three DNS tools. Fierce does DNS reconnaissance, brute-force subdomain enumeration, DNS zone transfer testing, and mapping internal/external IP ranges. DNSrecon does full DNS record enumeration, zone transfer testing (AXFR), subdomain brute-forcing, and reverse DNS lookups. DNSenum does similar things plus Google scraping to find additional subdomains.

Active Reconnaissance and Scanning

Now we move into the hands-on part where you directly interact with target systems.

Network Scanning

When you perform a network scan, you're actively sending probes (ARP or TCP/IP packets) to a network and analyzing the responses. The information you're trying to gather includes live hosts (which machines are online), their IP addresses, open ports, running services and their versions, operating systems, and potential vulnerabilities.

Understanding Ports in Depth

A port is a Transport Layer component — a virtual doorway that works alongside an IP address to direct network traffic to the correct application. Your IP address gets the data to the right machine; the port number gets it to the right application on that machine.

The three port ranges are: 0–1023 (well-known/system ports assigned to common services), 1024–49151 (registered/user ports for applications), and 49152–65535 (dynamic/private ports used temporarily by your operating system for outbound connections).

The well-known ports you need to memorize from your slides are: HTTP on 80, HTTPS on 443, Telnet on 23, SSH/SFTP on 22, FTP on 21 and 20, FTPS on 990 and 989, SMTP on 25, SMTPS on 465, IMAP on 143, IMAPS on 993, POP3 on 110, POP3S on 995, DHCP on 67 and 68, DHCPv6 on 546 and 547, DNS on 53, NTP on 123, SNMP on 161 and 162, SMB on 445, TFTP on 69, and RDP on 3389. Notice the pattern — many insecure protocols (HTTP, Telnet, FTP, SMTP) have secure counterparts on different port numbers.

Port states when scanning: Open means a service is actively listening, Closed means nothing is listening but the port is reachable (not blocked by a firewall), and Filtered means Nmap cannot determine the state because something (usually a firewall) is blocking the probe.

Nmap (Network Mapper)

This is the most important tool for your assignment. It handles host discovery, port scanning, service and version detection, OS detection, and scripting via NSE. The example from your slides shows `nmap -O -sV 192.168.182.129` which combines OS detection and version detection in one scan.

Masscan

Masscan is the fastest port scanner available — it can scan the entire internet in under 6 minutes by transmitting nearly 10 million packets per second. The example `sudo masscan -p1-65535 192.168.177.129 --rate 10000` scans all 65,535 ports at a rate of 10,000 packets per second. It's useful when speed matters more than detail.

Netcat

Called the "TCP/IP Swiss Army Knife," Netcat is a versatile networking tool. It handles port scanning and banner grabbing (reading the service identification text), works as both TCP client and server, transfers files over the network, and creates reverse and bind shells (used in penetration testing). The example `nc -zv 192.168.177.129 1-65535` scans all ports where `-z` means scan mode (don't send data) and `-v` means verbose output.

ARP-Scan

This tool discovers hosts on your local network using ARP (Address Resolution Protocol) packets. The advantage is that it works even when hosts block ICMP/ping requests. The example `sudo arp-scan -l` scans the local network. You can also specify an interface (`--interface=eth0`) or a specific subnet (`192.168.182.0/24`).

Netdiscover

Similar to ARP-Scan but with additional features like passive scanning mode (where it listens for ARP traffic without sending any packets itself) and automatic scanning mode. The example `sudo netdiscover -r 192.168.182.0/24` actively scans a specific subnet range.

nmapAutomator

This is a wrapper script that automates Nmap workflows. It offers predefined scan modes, combines TCP and UDP scanning, includes vulnerability scanning, and suggests additional recon based on discovered services. The example `nmapAutomator.sh -H 192.168.182.129 -t Port` runs a port scan type against the target.

Zenmap

This is the official GUI (graphical user interface) for Nmap. It provides predefined scan profiles, a command builder, network topology mapping, and saves scan results history. If you're uncomfortable with the command line, Zenmap lets you do the same scans through a visual interface.

Angry IP Scanner and NetScanTools

Angry IP Scanner is a lightweight, cross-platform, multi-threaded network scanner with a simple GUI. NetScanTools Pro is a Windows-based tool suite with over 50 tools including port scanning, DNS investigation, packet capture, WHOIS research, and automated reporting.